

API Security with Tyk: Rate Limiting Scopes

Learn how to define how rate limits apply across different levels.
Giving you fine-grained control to protect critical services and ensure
reliable performance

API-Level Rate Limiting

Protecting the whole API

- This limits how much total traffic the entire API can handle — no matter who is making the requests
- It protects your backend system from getting too many requests at once (which could slow it down or crash it). Think of it like setting a maximum capacity for a restaurant — once it's full, no one else can enter.

Key-Level Rate Limiting

Controlling each user or app:

- Limits how many requests each individual user or API key can make
- Prevents any one user from hogging the system or abusing their access

Types of Key-Level Limits:

- **Global (all APIs)** – Limit how many total requests this user/API key can make across everything they have access to
 - Example: “User123 can only make 500 requests per hour total.”
- **Per API** – Limit requests to one specific API
 - Example: “User123 can only make 200 requests per hour to the Billing API.”
- **Per Endpoint** – Limit requests to a specific path or function
 - Example: “User123 can only call /checkout/pay 10 times per minute.”

Endpoint-Level Rate Limiting

Endpoint-level rate limiting allows you to control how often a specific path or function in your API can be accessed

Helps protect critical or sensitive operations from being overloaded or abused.

- Example: User 123 can only make 10 req/min to checkout/pay

In Tyk, you can set this under key-level policies by defining custom limits per endpoint.